

Engineering: Data Security & Database Access Protocol

Version: 2026.3

Department: Engineering / Security

Classification: Confidential / Engineering Only

Type: Policy Document

1. Purpose

This protocol outlines the mandatory security standards for accessing, managing, and storing company and customer data. Adherence to these rules is required to maintain our SOC2 compliance and protect our users' privacy.

2. Data Classification levels

- **Level 4 (Top Secret):** Production database credentials, SSL private keys, and salt/pepper values for hashing.
- **Level 3 (Confidential):** Personally Identifiable Information (PII) such as user emails, addresses, and IP logs.
- **Level 2 (Internal):** Internal architecture diagrams, roadmap documents, and unreleased source code.
- **Level 1 (Public):** Documentation, public marketing assets, and open-source contributions.

3. Database Access Control (RLS & IAM)

3.1 Production Access

- **No Manual Edits:** Direct manual manipulation of the production database (via GUI or CLI) is strictly prohibited except during SEV-1 incidents.
- **Just-in-Time (JIT) Access:** Engineers must request temporary access via the security-bot in Slack. Access is granted for a maximum of 4 hours and is fully audited.
- **Row-Level Security (RLS):** All application-level queries must utilize Postgres RLS. Bypassing RLS by using the `service_role` key in frontend code is a terminable offense.

3.2 Development & Staging

- **Sanitized Data:** Development environments must never use real customer PII. Use the `scripts/db-sanitize.sh` tool to clone production schemas with mocked data.
- **Local Secrets:** Never commit `.env` files to GitHub. Use the company's secret manager

(Infisical/1Password) to inject environment variables at runtime.

4. Encryption Standards

- **Data at Rest:** All production volumes must be encrypted using AES-256.
- **Data in Transit:** All external and internal traffic must be forced over TLS 1.3.
- **Field-Level Encryption:** Sensitive PII (Social Security Numbers, Bank Details) must be encrypted at the application layer before being sent to the database.

5. Security Incident Reporting

If you suspect a data breach, credential leak, or unauthorized access:

1. **Do not** discuss the breach in public Slack channels.
2. **Immediately** notify the Security Lead via the encrypted signal line provided in your onboarding kit.
3. Follow the **SEV-1 Protocol** outlined in the Incident Response Runbook.

6. Prohibited Actions

- Sharing your VPN or database credentials with anyone, including other engineers.
- Storing production data backups on local machines or unencrypted external drives.
- Hard-coding API keys or secrets in any source code repository.

Compliance Check: This document is audited quarterly. Failure to comply with the protocols listed above will result in immediate revocation of system access and formal disciplinary review.